



Compliance Officer Manual

TASCO Insurance × VETC Growth Platform — User Manuals

iorta TechNXT

Version 1.0 · 07 October 2026

Contents

1. Regulatory controls built into the platform
2. Approving rule changes
3. Governance dashboard
4. Searching the audit trail
5. Data subject requests (DSAR)
6. Monthly compliance checklist
7. Troubleshooting

Role: `compliance_officer` · **Demo user:** `compliance` · **MFA:** required

Your permissions: read rules (`rules:read`), **approve or reject rules** (`rules:approve`), **read the audit trail** (`audit:read`), dashboards including governance (`dashboard:read`), **data subject requests** (`dsar:manage`), view customer records with personal data masked (`profile:read`).

You are the platform's second line of defence. You approve customer-facing and regulated rule changes, evidence compliance through the audit trail, and execute data subject access and erasure requests.

Read the [Staff User Manual](#) first. For approving rule changes, follow the approver steps in the [Rule Author and Approver Manual](#).

1. Regulatory controls built into the platform

Obligation	Control in the platform	Where you check it
No unlawful discounts or inducements on price-regulated TNDs (Law on Insurance Business 08/2022/QH15)	Copy guard (<code>copy_guard</code>) blocks banned phrases when content is saved and again when a message is sent. Quotes for regulated products carry no discount field.	Rules studio (<code>copy_guard</code> , <code>content.*</code> , <code>benefits</code>); Home → message status "blocked"
Benefits must be lawful	Each benefit has <code>legalStatus</code> . Only approved items reach customers. Staff see <code>pending_legal_review</code> items flagged.	Rules studio (<code>benefits</code>); <code>referral</code> is disabled
Anti-spam (Decree 91/2020/ND-CP)	Contact policy: 08:00–20:00 ICT for marketing, ≤ 1 marketing contact per day and ≤ 3 per week, ≤ 2 call attempts per week, consent per channel, do-not-contact honoured	Rules studio (<code>contact_policy</code>); skipped touchpoints show reasons
Personal data protection (Decree 13/2023/ND-CP and the PDP Law)	Consent centre (customer app). Purpose-based masking. Field-level encryption. DSAR export and erasure. Retention rule set. Every customer view audited.	Audit page, DSAR actions, <code>retention</code> rule set
Voice AI transparency	Bot discloses it is automated, states the call is recorded, never asks for OTP or payment, verifies the plate first and offers a human	Rules studio (<code>content.voicebot</code>); governance dashboard
Commission caps (Ministry of Finance rules)	<code>statutoryCaps</code> in <code>commission</code> enforced at validation and at calculation	Rules studio (<code>commission</code>)
Four-eyes control on business rules	Maker-checker enforced in code	Audit: <code>rules.approved</code> shows the approver differs from the author
Tamper-evident records	Append-only, hash-chained audit trail with verification	Audit → Verify chain

2. Approving rule changes

Follow the approver procedure in the [Rule Author and Approver Manual](#). Compliance-specific checks:

Customer content (`content.messages` , `content.voicebot` , `benefits`):

- ☐ Vietnamese text is clear, polite and truthful. The English text matches it.

- ☐ No price-reduction wording or implication (the copy guard catches listed phrases; you catch the rest, for example "ưu đãi phí", "tiết kiệm hơn").
- ☐ No promise of loyalty points, referral rewards or gifts unless legally approved.
- ☐ The voice script keeps: automated-assistant disclosure, recording notice, "VETC không bao giờ yêu cầu mã OTP hay thanh toán qua điện thoại", plate-first verification, human option, opt-out handling.
- ☐ New ZNS templates have been (or will be) approved by Zalo before activation.

Policy kinds (`contact_policy` , `retention` , `copy_guard` , `abac`):

- ☐ The change is backed by a Legal/DPO or Security decision (reference in the comment).
- ☐ Caps and consent are not loosened without that decision.
- ☐ Removing phrases from `copy_guard` is treated as high risk.

Record your rationale in the **Review comment**. It is stored in the audit trail.

3. Governance dashboard

1. Open **Home** and select the **Governance** tab.
2. **What you will see:**

Block	Meaning	What to watch
Voice bot calls: total, outcomes	How AI calls end	Spikes in <code>opted_out</code> , <code>wrong_person</code> , <code>plate_mismatch</code>
Plate verification failure rate	$(\text{plate_mismatch} + \text{unverified}) \div \text{calls}$	Proposed tolerance $\leq 15\%$ (pilot)
Opt-out rate	$\text{opted_out} \div \text{calls}$	Proposed tolerance $\leq 5\%$ (pilot)
Disclosure policy	"automated assistant disclosed at call start; no payment or OTP requested"	Must stay true. Check the active voice script.
Rule sets by status	Counts of draft, pending_approval, active, retired, rejected	Pending items waiting more than 1 business day
Audit chain	Verification result: <code>ok</code> , entry count, head hash, or the broken position	Must be <code>ok</code>

Review it weekly and report monthly to the Rules Governance Board.

4. Searching the audit trail

1. Open **Audit**.
2. Search by any combination of:
 - **Entity id:** for example a customer/plate ID (`30A12345`), rule version (`scoring@3`), handoff (`H0-...`), claim (`CL-...`), order (`0-...`), partner (`P-...`), user (`U-...`);
 - **Actor:** the user ID (`U-...`), `system` , `cron` , `journey-engine` , `customer:<id>` or `partner:<id>` ;
 - **Action:** see the table below.
3. Select **Search**.

What you will see: entries with time, actor, action, entity and details, plus each entry's hash. Personal data is never written into audit details (IDs only).

Area	Actions
Access	auth.login , auth.login_failed , auth.login_locked , auth.mfa_failed , auth.password_changed , user.created , user.updated
Customer data	profile.viewed (with whether PII was visible), profile.expiry_corrected , customer.expiry_declared , consent.updated , consent.withdrawn , dsar.access_exported , dsar.erased
Rules	rules.seeded , rules.draft_created , rules.submitted , rules.approved , rules.rejected
Sales	quote.created , order.completed , order.payment_failed , order.issuance_failed
Engagement	journeys.run , ecosystem.event_handled , voice.call_completed , handoff.updated , leads.recomputed
Claims	claim.submitted , claim.status_changed
Partners	partner.created , partner.status_changed , partner.api_key_issued , partner.api_key_revoked
Data and operations	data.ingested , dq.resolved , job.reconciliation , job.retention

Typical evidence queries:

- *Who approved the current tariff?* Entity `tariff.tnds_car@<n>` , action `rules.approved` .
- *Who looked at this customer last month?* Entity = plate ID, action `profile.viewed` .
- *Has this customer withdrawn consent?* Entity = plate ID, actions `consent.updated` and `consent.withdrawn` .

4.1 Verify the audit chain

1. In **Audit**, select **Verify chain**.
2. **What you will see:** **OK** with the number of entries and the head hash, or **Broken at entry N** with a reason (prev hash mismatch / hash mismatch).
3. If broken: **do not** attempt any fix. Record the result, notify Security and the platform owner at once, and preserve evidence (incident procedure).

Recommended: verify daily (support can automate it) and before every external audit.

5. Data subject requests (DSAR)

Customers can download their own data in the customer app (**Tài khoản** → **Tải dữ liệu của tôi**). You handle requests received through other channels (hotline, email, letter) and all **erasure** requests.

5.1 Before you act

1. Log the request in the DSAR register: date received, channel, request type, legal deadline.
2. **Verify identity** through the agreed procedure (for example, a request from the registered phone through the VETC app, or ID document checked by customer service). Never act on unverified requests.
3. Identify the customer ID (normalised plate, for example `30A12345`).

5.2 Right of access: export

1. Open **Audit** and search the customer ID, or open the customer in **Customer 360**.

2. Select **DSAR** → **Export data**.
3. **What you will see:** a JSON package generated now, containing the profile, lead record, policies, messages, source records and voice sessions. Download it.
4. Deliver it to the customer through the secure channel agreed by the DPO (never ordinary email attachments without protection).
5. The action is audited as `dsar.access_exported`.

5.3 Right to erasure: anonymise

1. Confirm that erasure is legally appropriate. Records the law requires us to keep (policies, financial records) are retained but de-linked.
2. Select **DSAR** → **Erase (anonymise)**, read the confirmation and confirm.
3. **What you will see:**
 - **Success:** "Erased". Name and phone are removed, the customer is marked do-not-contact, the lead is deleted, source records lose phone and name, messages become "[erased]" and voice transcripts are cleared. Audited as `dsar.erased`.
 - **Refused:** "Active policy in force — personal data must be retained until expiry (legal obligation)". Tell the customer the reason and the date after which erasure can proceed. Diary the follow-up.
4. Erasure cannot be undone.
5. **Known v1 gap (KI-29):** erasure does not yet anonymise telesales **handoffs** (name, masked phone, talking points), **claims** (description, location) or **quotes** (plate). Until it is fixed, raise a ticket with support to anonymise these records manually, and record it in the DSAR register.

5.4 Consent withdrawal and objection to marketing

Customers can switch off marketing and calls in the app's consent centre, or ask the voice bot to stop calling ("đừng gọi nữa"), which records do-not-contact immediately. For requests received elsewhere, ask customer service to record them through the approved channel and verify `consent.updated` in the audit trail.

6. Monthly compliance checklist

- ☐ Audit chain verified OK.
- ☐ All rule activations in the month have a maker and a different checker. Comments are present for regulated kinds.
- ☐ No `pending_legal_review` benefit shown to customers. `referral.enabled` is still false unless approved.
- ☐ Message status: zero sends blocked by the copy guard in production, or each one investigated.
- ☐ Opt-out and complaint trends reviewed. Contact policy still appropriate.
- ☐ DSARs closed within deadlines. Erasure refusals followed up.
- ☐ Access review of privileged roles (with Security).
- ☐ Commission statements reconciled for sample partners.

7. Troubleshooting

Problem	Fix
MFA code rejected	Use the newest code. Check your phone clock. After 5 failures, wait 15 minutes.
Customer data masked in Customer 360	Expected. Your role does not need unmasked PII. DSAR export contains the full data for the data subject.

Problem	Fix
"Missing permission dsar:manage"	Only compliance officers can run DSAR actions
"Customer not found" on DSAR	Check the plate normalisation (no spaces or dots), or the customer is already anonymised

See also: [Rule Author and Approver Manual](#), [Data Steward Manual](#).